

CyberVerse AI - Security and Access Document

3.1 Authentication and Authorization

- Passwords: salted hash (bcrypt-family), never plaintext.
- Sessions: JWT bearer (cv_token); expiry enforced; invalid token -> clean re-login.
- Password reset: signed short-lived tokens; generic response prevents account enumeration.
- Authorization: per-user row filtering (user_id scoping) on all data endpoints.
- Admin: email allowlist (ADMIN_EMAIL list) on /api/admin/; 403 otherwise.

3.2 Payments Security

- Card data never touches the app (Razorpay-hosted) -> minimal PCI scope.
- Webhooks verified via HMAC-SHA256 (X-Razorpay-Signature); invalid -> 400.
- Upgrades idempotent; amount-based tiering (49900 -> Pro; 99900 -> Premium).

3.3 Controls Matrix

Control	Status
TLS everywhere (Render)	Done
Rate limiting (slowapi) on auth + AI	Done
ORM parameterized queries (SQLi)	Done
Secrets in platform env, not repo	Done
Email failures non-raising (no info leak)	Done
Server-side entitlement checks	Done

3.4 Known Risks and Remediations

Risk	Severity	Remediation
XSS via innerHTML rendering of AI text	High	Escape/DOMPurify all AI/user content (CV-105)
Password-reset link points to / not /app.html	High	Fix link + token handler (CV-126)
No signup email verification	Medium	Verify step (CV-130)
JWT default secret if env missing	Medium	Fail-fast on default in prod
Resume text retained indefinitely	Medium	Retention/deletion policy (CV-135)
Admin = email allowlist only	Low	Add 2FA/magic-link later
No audit log	Low	Log admin + webhook events (CV-134)

3.5 Compliance Notes

PCI-DSS out of scope via Razorpay. Publish Privacy Policy + Terms (CV-135). Support data-deletion requests (DPDP/GDPR posture). Transactional email only (Resend).